
Cuadernillo de Estudio — Clase 2

Seguridad vs. Hacking. Cultura Hacker y Ética

Seguridad Aplicada a Sistemas de Información
 Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
 Docente: Ing. Rodrigo Atilio Elgueta
 Ciclo Académico Vigente

Índice

1. Objetivos de aprendizaje	2
2. Punto de partida: la experiencia SeguridadTest	2
3. La Seguridad de la Información y la Tríada CIA	3
4. Hacking: deconstrucción del término	4
4.1. Mito vs. realidad	4
4.2. Breve historia de la cultura hacker	4
5. La ética hacker	5
6. Clasificación de actores: los «sombreros»	6
7. Casos de debate trabajados en clase	6
7.1. Caso A: El hallazgo accidental	7
7.2. Caso B: Hacktivismo	7
8. Glosario de conceptos clave	7
9. Autoevaluación	7
10. Respuestas de la Autoevaluación	8
11. Recordatorio: Actividad A01	11
12. Fuentes y bibliografía	11
12.1. Bibliografía obligatoria (según programa)	11
12.2. Bibliografía complementaria (según programa)	12
12.3. Portales y recursos web	12
12.4. Material audiovisual sugerido	12

1. Objetivos de aprendizaje

Al finalizar la lectura y el trabajo con este cuadernillo, el estudiante será capaz de:

- Deconstruir y definir las terminologías **seguridad** y **hacking**, separando el mito cultural de la definición técnica.
- Definir **vulnerabilidades**, **riesgos**, **amenazas**, **activos** y **salvaguardas**, identificando agentes e incidencias.
- Aplicar los conceptos de **Confidencialidad**, **Integridad** y **Disponibilidad** (Tríada CIA) como elementos a proteger.
- Reconocer la **cultura hacker**: sus inicios históricos, técnicas y evolución.
- Comprender la **ética hacker** original y desarrollar criterio ético-profesional frente a dilemas de seguridad.

Cómo usar este cuadernillo

Este material acompaña la Clase 2. Léelo **antes** del cursado, trae tus dudas al aula y utiliza la sección de autoevaluación (Sección 9) para prepararte para el cuestionario A02 y el informe A01. Las respuestas de referencia se encuentran en la Sección 10.

2. Punto de partida: la experiencia SeguridadTest

En la Clase 1 utilizamos el proyecto **SeguridadTest**¹: una aplicación web que, mediante un código QR, capturaba el video de los celulares de los estudiantes y lo transmitía en el proyector del aula, mostrando además recomendaciones de ciberseguridad, sitios anti-phishing y consultas de huella digital en la red.

La experiencia no fue un truco de magia: fue una demostración controlada de cómo funcionan las amenazas reales.

Para reflexionar

- ¿Qué sentiste al ver tu cámara o tus datos proyectados frente a toda la clase?
- ¿Confiamos demasiado en las aplicaciones que instalamos y en las redes a las que nos conectamos?
- ¿Qué hubiera pasado si en lugar de la cátedra, quien captura esa información fuera un delincuente?

De esa experiencia surgen los conceptos básicos que usaremos todo el cuatrimestre:

Activo

Todo elemento de hardware, software, datos o recurso humano que tiene **valor** para una organización o persona y que, por lo tanto, debe protegerse.

Amenaza

Agente o evento (persona, proceso, fenómeno) con potencial de causar daño a un activo. Puede ser intencional (un atacante) o accidental (un incendio, un error humano).

¹Disponible en <https://github.com/arelgueta/SeguridadTest>

Vulnerabilidad

Debilidad o falla en el diseño, implementación u operación de un sistema que puede ser **explotada** por una amenaza.

Riesgo

Probabilidad de que una amenaza explote una vulnerabilidad, multiplicada por el **impacto** que ese evento causaría sobre el activo.

Salvaguarda / Contramedida

Control o medida (técnica, física o administrativa) que reduce la vulnerabilidad o el impacto de la amenaza.

Aplicado a SeguridadTest

- **Activo:** tu celular y tus datos personales (cámara, identidad digital).
- **Vulnerabilidad:** aceptar permisos o conectarse a una red sin verificar quién está del otro lado.
- **Amenaza:** un atacante que replica la misma técnica con fines maliciosos (phishing, spyware).
- **Riesgo:** exposición de tu privacidad y huella digital.
- **Salvaguarda:** concientización, verificación de permisos, navegación segura.

3. La Seguridad de la Información y la Tríada CIA

La **Seguridad de la Información** es el conjunto de medidas técnicas, físicas y administrativas destinadas a proteger la información y los sistemas que la procesan, garantizando un nivel razonable de manejo de la privacidad, integridad y disponibilidad según la criticidad del sistema.

Todo el diseño de la seguridad a nivel mundial se apoya en tres pilares, conocidos como la **Tríada CIA** (por sus siglas en inglés: *Confidentiality, Integrity, Availability*):

Confidencialidad (C)

La información solo es accesible para quienes poseen **autorización**. Se protege mediante cifrado, control de accesos, autenticación y clasificación de la información.

Integridad (I)

La información **no ha sido alterada** por personas o procesos no autorizados. Se protege mediante hashes, firmas digitales, control de versiones y permisos de escritura.

Disponibilidad (A)

La información y los sistemas están **accesibles cuando se los necesita**. Se protege mediante redundancia, copias de seguridad (backups), UPS y planes de contingencia.

Fallas de cada pilar

- **Confidencialidad:** un empleado sube una planilla de sueldos a un repositorio público de Internet.
- **Integridad:** un atacante intercepta un correo y cambia el número de cuenta (CBU/CVU) de destino de un pago a proveedores.
- **Disponibilidad:** un ataque de *ransomware* o de denegación de servicio (DDoS) deja fuera de línea el sistema de una universidad en semana de exámenes.

A estos pilares se suman propiedades complementarias que veremos a lo largo de la materia:

- **Autenticidad:** garantía de que la entidad es quien dice ser.
- **No repudio:** nadie puede negar una acción realizada (origen y destino comprobables).
- **Trazabilidad:** posibilidad de reconstruir los eventos mediante registros (logs).

Seguridad vs. Operatividad

La seguridad **no es un producto, es un proceso** y nunca es absoluta: se **gestiona** mediante riesgos. Además, existe una tensión permanente entre seguridad y operatividad: un sistema totalmente seguro sería inutilizable (nadie podría acceder a él), y un sistema totalmente operativo sería inseguro. El profesional de sistemas debe encontrar el punto de equilibrio según la criticidad del activo.

4. Hacking: deconstrucción del término

4.1. Mito vs. realidad

El cine y la televisión construyeron la imagen del hacker como un joven encapuchado, en un sótano oscuro, tipeando frenéticamente mientras «rompe» sistemas en segundos. La realidad técnica y cultural es muy distinta.

Hacker (definición original)

Persona que disfruta de la **exploración intelectual** de los límites de los sistemas, con curiosidad profunda por entender cómo funcionan las cosas y por superar obstáculos de manera **creativa e ingeniosa**. El término no implica delito: implica conocimiento y creatividad.

Hacking

Acción de explorar, analizar y manipular el funcionamiento de un sistema más allá de su uso convencional, con el fin de entenderlo, optimizarlo o superar sus límites. Según el contexto, la autorización y la intención, puede ser una actividad **legal y profesional** (hacking ético) o un **delito** (ciberdelincuencia).

4.2. Breve historia de la cultura hacker

La cultura hacker se desarrolló por etapas, cada una con sus propios hitos:

- **Los orígenes (MIT):** en el *Tech Model Railroad Club* del MIT nace el término *hack*: una solución ingeniosa o broma técnica elaborada. Los primeros «hacks» optimizaban las vías de trenes a escala y luego migraron a las primeras computadoras del laboratorio (PDP-1).
- **La época del Phreaking:** el «hacking» de la red telefónica. **John Draper**, apodado *Captain Crunch*, descubre que un silbato incluido en una caja de cereales emitía un tono de **2600 Hz**, la frecuencia que los conmutadores de AT&T usaban para señalar líneas libres. Con silbatos y luego «blue boxes» se podían realizar llamadas gratuitas. El artículo *Secrets of the Little Blue Box* (Rosenbaum, revista *Esquire*) popularizó el fenómeno.
- **El auge de las BBS y primeras intrusiones:** surgen los *Bulletin Board Systems*, los grupos hackers y las primeras intrusiones en redes como ARPANET. Bajo el seudónimo *The Mentor* se publica en la revista *Phrack* el **Manifiesto Hacker** (*The Conscience of a Hacker*), texto fundacional de la cultura.
- **Internet y profesionalización:** la masificación de Internet trae los primeros virus difundidos globalmente, nacen los equipos de respuesta a incidentes (CERT) y la seguridad comienza a profesionalizarse.
- **La era actual — Ciberdelito, hacktivismo y hacking ético:** conviven el crimen organizado (ransomware, fraudes), los grupos hacktivistas, los ataques patrocinados por Estados (APT) y, del otro lado, una industria profesional de seguridad ofensiva legal: pentesters, bug bounty y certificaciones.

5. La ética hacker

El periodista Steven Levy, en su libro *Hackers: Heroes of the Computer Revolution*, sistematizó los principios originales de la comunidad:

1. El acceso a las computadoras —y a todo lo que pueda enseñarte cómo funciona el mundo— debe ser **ilimitado y total**.
2. Toda la información debe ser **libre**.
3. Desconfía de la autoridad; promueve la **descentralización**.
4. Los hackers deben juzgarse por su **hacking**, no por títulos, edad, raza o posición social.
5. Se puede crear **arte y belleza** en una computadora.
6. Las computadoras pueden **cambiar tu vida para mejor**.

Ética original vs. marco legal actual

Varios de estos principios, leídos literalmente, entran en colisión con la legislación vigente (por ejemplo, la Ley de Delitos Informáticos en Argentina, que modifica el Código Penal). ¿Sigue vigente el manifiesto hacker? La respuesta profesional es: la **curiosidad** y el **espíritu de comprender** siguen siendo el motor del buen profesional de seguridad; pero el **método** debe encuadrarse en la autorización y la ley. Esa tensión es la que separa al White Hat del Black Hat.

Hoy, esa ética se canaliza profesionalmente mediante:

Divulgación responsable (*Responsible Disclosure*)

Práctica por la cual un investigador que descubre una vulnerabilidad la reporta **de forma privada** al responsable del sistema, otorgando un plazo razonable para el parche antes de cualquier publicación.

Bug Bounty

Programas mediante los cuales organizaciones **autorizan y remuneran** a investigadores por reportar vulnerabilidades siguiendo reglas claras de alcance y conducta.

6. Clasificación de actores: los «sombreros»

La comunidad adoptó la metáfora de los sombreros (*hats*) del cine western para clasificar a los actores según su autorización y motivación:

Perfil	¿Autorización	Motivación / Ejemplo típico
White Hat (Sombrero Blanco)	Sí	Mejorar la seguridad. Pentester contratado, auditor, investigador con contrato firmado.
Black Hat (Sombrero Negro)	No	Lucro o daño. Ciberdelincuente, operadores de ransomware, robo de datos.
Grey Hat (Sombrero Gris)	No, pero sin malicia	Curiosidad o reconocimiento. Entra sin permiso, avisa al dueño (a veces pide «recompensa»).
Hacktivista	No	Causa política o social. Defacement de sitios, filtraciones con mensaje ideológico.
Script Kiddie	No	Diversión o ego. Usa herramientas de terceros sin comprender cómo funcionan.
Insider (Amenaza interna)	Tenía acceso	Venganza, lucro o negligencia. Empleado descontento que filtra información.
APT	No	Espionaje o geopolítica. Grupos sofisticados, en general patrocinados por Estados.

La línea roja es la autorización

Lo que separa al hacking ético del ciberdelito no es la técnica ni la herramienta: es la **autorización expresa y documentada** (contrato de pentesting, alcance definido, reglas de enfrentamiento). Sin autorización, cualquier acceso a un sistema ajeno es un delito, aun con «buenas intenciones».

7. Casos de debate trabajados en clase

Repasa los dilemas discutidos en el aula; pueden retomarse en cuestionarios y parciales.

7.1. Caso A: El hallazgo accidental

Buscando APIs públicas para un proyecto de la facultad, por un error de tipeo en una URL accedes a la base de datos de pacientes de una clínica privada: nombres, DNI y diagnósticos médicos, sin contraseña. ¿Qué hacés? ¿Descargarla para «asegurar la evidencia»? ¿Cerrar la pestaña y olvidar? ¿Contactar al responsable de sistemas? ¿Avisar a la prensa?

Ejes de análisis: divulgación responsable, proporcionalidad, Ley de Protección de Datos Personales (Habeas Data), riesgo legal de «probar» que la base es accesible descargándola.

7.2. Caso B: Hacktivismo

Un grupo derriba el sitio web de una empresa acusada de contaminar un río y borra sus bases de datos de producción para frenar su operación. ¿Héroes o ciberdelincuentes? ¿Qué pilares de la Tríada CIA se violan? ¿El fin justifica los medios en el marco legal vigente?

8. Glosario de conceptos clave

Activo	Elemento con valor a proteger (datos, hardware, software, personas).
Amenaza	Agente o evento con potencial de dañar un activo.
Vulnerabilidad	Debilidad explotable de un sistema.
Riesgo	Probabilidad × impacto de que una amenaza explote una vulnerabilidad.
Salvaguarda	Control que reduce el riesgo.
Tríada CIA	Confidencialidad, Integridad y Disponibilidad.
Hacking	Exploración creativa de los límites de un sistema.
Hacker	Quien disfruta esa exploración; no implica delito.
Hacking ético	Hacking autorizado con fines de auditoría y mejora.
Phreaking	Hacking de redes telefónicas; origen cultural del hacking moderno.
Phishing	Ingeniería social que suplanta identidad para robar credenciales o datos.
Ingeniería social	Manipulación de personas para obtener información o accesos.
Bug Bounty	Programa autorizado y remunerado de reporte de vulnerabilidades.

9. Autoevaluación

Respondé por escrito y sin apuntes; luego verificá con el cuadernillo y la bibliografía. Las respuestas de referencia están en la Sección 10.

- Definí con tus palabras la diferencia entre **amenaza** y **vulnerabilidad**, con un ejemplo propio distinto al del cuadernillo.
- Enumera los tres pilares de la Tríada CIA y presentá un caso real de falla de cada uno.
- ¿Por qué el caso de *Captain Crunch* y el tono de 2600 Hz es un hito de la cultura hacker?
- Enunciá al menos tres principios de la ética hacker según Steven Levy.
- Clasificá los siguientes escenarios (White / Black / Grey Hat, Hacktivista, Script Kiddie):

- a) Consultora que prueba la seguridad de un banco con contrato firmado.
 - b) Usuario que roba credenciales para venderlas en foros clandestinos.
 - c) Persona que entra sin permiso a un sistema expuesto, solo para avisar al dueño.
 - d) Grupo que derriba un sitio en protesta por una ley impopular.
 - e) Aficionado que lanza un ataque copiado de un video, sin entenderlo.
6. Verdadero o falso, justificando: «Todo hacker es un delincuente».
7. ¿Qué es la divulgación responsable y en qué se diferencia de extorsionar al vendor?
8. Explicá la relación entre **operatividad y seguridad** de un sistema.

10. Respuestas de la Autoevaluación

Nota para el estudiante

Estas respuestas son **de referencia**. En el examen se valora la argumentación propia, el uso de ejemplos y la capacidad de relacionar conceptos. No se espera una respuesta literal, sino que demuestres comprensión.

Pregunta 1: Amenaza vs. Vulnerabilidad

Respuesta

La **amenaza** es el agente o evento que tiene el *potencial* de causar daño (el «quién» o el «qué» ataca). La **vulnerabilidad** es la *debilidad* del sistema que puede ser aprovechada por esa amenaza (el «por dónde» entra).

La amenaza existe independientemente del sistema; la vulnerabilidad es una condición del sistema. Una amenaza sin vulnerabilidad no genera riesgo; una vulnerabilidad sin amenaza que la explote tampoco.

Ejemplo propio:

- **Amenaza:** un rayo durante una tormenta eléctrica.
- **Vulnerabilidad:** el servidor de la empresa no tiene UPS ni descarga a tierra.
- **Riesgo resultante:** que el rayo dañe el servidor y se pierdan datos.

Pregunta 2: Tríada CIA con casos reales

Respuesta

- **Confidencialidad:** falla cuando información que debía ser privada se expone. **Caso real:** la filtración de datos de usuarios de una red social, donde nombres, correos y contraseñas quedaron accesibles públicamente.
- **Integridad:** falla cuando la información es alterada sin autorización. **Caso real:** un atacante que modifica registros de una base de datos financiera para cambiar montos de transferencias.
- **Disponibilidad:** falla cuando el sistema no está accesible cuando se lo necesita. **Caso real:** un ataque DDoS que satura los servidores de un banco en línea y deja a los clientes sin acceso a sus cuentas durante horas.

Pregunta 3: Captain Crunch y el hito del Phreaking

Respuesta

El caso de *Captain Crunch* (John Draper) es un hito porque demostró, por primera vez de forma pública, que era posible **entender y explotar** un sistema complejo (la red telefónica de AT&T) utilizando una debilidad técnica no evidente: la frecuencia de señalización de 2600 Hz que los conmutadores usaban para indicar líneas libres.

Su relevancia cultural radica en varios puntos:

- Mostró que la **curiosidad técnica** podía desafiar a grandes corporaciones.
- Estableció el patrón del hacking como **exploración creativa** de límites, no solo como delito.
- Inspiró a generaciones posteriores (incluidos los fundadores de Apple, que vendieron blue boxes en sus inicios).
- Marcó el nacimiento del **phreaking** como primera subcultura hacker.

Pregunta 4: Principios de la ética hacker (Steven Levy)

Respuesta

Tres principios posibles (el enunciado pide al menos tres de los seis):

1. El acceso a las computadoras debe ser **ilimitado y total**.
2. Toda la información debe ser **libre**.
3. Se debe **desconfiar de la autoridad** y promover la descentralización.
4. Los hackers deben juzgarse por su **hacking**, no por títulos o posición social.
5. Se puede crear **arte y belleza** en una computadora.
6. Las computadoras pueden **cambiar tu vida para mejor**.

Nota: en el examen, enunciar tres con sus palabras clave es suficiente. Si podés desarrollarlos con una frase explicativa cada uno, mejor.

Pregunta 5: Clasificación de escenarios

Respuesta

1. Consultora con contrato firmado → **White Hat** (autorización expresa, fin legítimo de auditoría).
2. Usuario que roba credenciales para venderlas → **Black Hat** (sin autorización, fin lucrativo).
3. Persona que entra sin permiso solo para avisar → **Grey Hat** (sin autorización, pero sin malicia; motivación ética aunque el método no sea legal).
4. Grupo que derriba un sitio en protesta → **Hactivista** (sin autorización, motivación

política o social).

5. Aficionado que copia un ataque sin entenderlo → **Script Kiddie** (sin conocimiento técnico propio, usa herramientas ajenas).

Pregunta 6: Verdadero o Falso — «Todo hacker es un delincuente»

Respuesta

FALSO.

El término «hacker» en su origen y definición técnica se refiere a una persona que disfruta de la exploración intelectual de los límites de los sistemas. No implica actividad delictiva. Lo que determina si una actividad de hacking es delito o no es la **autorización**:

- Con autorización (contrato, alcance definido) → hacking ético, actividad profesional y legal (White Hat).
- Sin autorización → acceso ilegal a sistemas, tipificado como delito en el Código Penal argentino (Ley de Delitos Informáticos).

Por lo tanto, la afirmación confunde la **técnica** (hacking) con el **delito** (ciberdelincuencia). Un pentester contratado por una empresa para auditar sus sistemas es un hacker, pero no un delincuente.

Pregunta 7: Divulgación responsable vs. extorsión

Respuesta

La **divulgación responsable** (*Responsible Disclosure*) es la práctica por la cual un investigador que descubre una vulnerabilidad la reporta de forma privada al responsable del sistema, otorgando un plazo razonable para que se desarrolle el parche antes de cualquier publicación pública.

La **diferencia con la extorsión** radica en la **motivación** y el **método**:

	Divulgación responsable	Extorsión
Motivación	Proteger usuarios y sistemas	Beneficio propio (dinero, reconocimiento forzado)
Método	Reporta en privado, colabora, espera	Amenaza con publicar si no se paga
Resultado esperado	Parche, protección del sistema	Pago al atacante
Marco legal	Puede ser recompensada (Bug Bounty)	Es un delito

Pregunta 8: Relación entre operatividad y seguridad

Respuesta

Existe una **tensión permanente** (trade-off) entre seguridad y operatividad:

- A mayor seguridad, generalmente **menor comodidad** y operatividad (más autenticaciones, restricciones, controles).
- A mayor operatividad y apertura, generalmente **menor seguridad** (menos barreras, más superficie de ataque).

Extremos teóricos:

- Un sistema 100 % seguro sería **inutilizable** (nadie podría acceder a él).
- Un sistema 100 % operativo sería **completamente inseguro** (cualquiera podría acceder y modificar todo).

El rol del profesional de sistemas es encontrar el **punto de equilibrio** según la criticidad del activo, el nivel de riesgo aceptable y los requisitos del negocio. Esto se logra mediante el análisis de riesgos: no se protege todo por igual, sino que se priorizan los activos más críticos y se diseñan controles proporcionales.

Esta relación está directamente vinculada al concepto de **riesgo residual**: siempre queda un nivel de riesgo aceptado, porque eliminar todo el riesgo haría imposible operar.

11. Recordatorio: Actividad A01

Consigna A01 — Hacking ¿qué es?

Leer la bibliografía «Hacking ético» y elaborar un informe respecto a la **cultura hacker**: sus inicios, técnicas y ética. El informe se sube a la carpeta del Trabajo Integrador en Google Drive creada en la Clase 1, otorgando permisos de comentario a era.profe@gmail.com.

Rúbrica de evaluación (según grilla de la cátedra):

Criterio	Peso	Qué se espera para el «Excelente»
A. Recopilación de información	30 %	Utiliza de manera completa fuentes confiables y las cita correctamente.
B. Elaboración de documentos	30 %	Cumple adecuadamente con los formatos de la planilla de estandarización brindada por la cátedra.
C. Elaboración de presentaciones	10 %	Argumenta de manera sólida el caso analizado y su solución.
F. Consciencia de buenas prácticas	30 %	Evidencia permanentemente el uso de buenas prácticas.

12. Fuentes y bibliografía

12.1. Bibliografía obligatoria (según programa)

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.

- Elgueta, R. (s.f.). *Guías de Clase unidad I*. Material inédito. UCH.

12.2. Bibliografía complementaria (según programa)

- Bancal, D. (2022). *Seguridad informática* (5.^a ed.). Ediciones ENI.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing to Audit and Improve the Cybersecurity of Computer Networks for Beginners, Including Tips on Social Engineering*. Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.
- ISO/IEC (2005). *Information security management 27001*.
- Lardent, A. R. (2001). *Sistemas de información para la gestión empresarial: procedimientos, seguridad y auditoría*. Pearson Publications.
- Horton, M. & Mugge, C. (2003). *Network security portable reference*. McGraw-Hill/Osborne.
- Levy, S. (1984). *Hackers: Heroes of the Computer Revolution*. O'Reilly.
- The Mentor. (1986). *The Conscience of a Hacker*. Phrack, n.º 7.
- Rosenbaum, R. (1971). *Secrets of the Little Blue Box*. Esquire.

12.3. Portales y recursos web

- Portales CERT, NIST, Hispasec y otros relacionados (bibliografía complementaria del programa).
- Proyecto de la cátedra (Clase 1): <https://github.com/arelguea/SeguridadTest>
- Manifiesto Hacker original: <http://www.phrack.org/issues/7/3.html>
- Laboratorios prácticos (se usarán más adelante en la materia): <https://tryhackme.com>
- Electronic Frontier Foundation: <https://www EFF.org>

12.4. Material audiovisual sugerido

- Documental *Hackers: Heroes of the Computer Revolution* (2001).
- *WarGames* (1983) — análisis crítico de ficción vs. realidad.
- Serie *Mr. Robot* — representación moderna del hacking en la cultura popular.